

This five-volume series is a comprehensive, implementation-oriented architecture guide for building enterprise-wide authorization and request interception frameworks for Agentic AI systems deployed on AWS. It addresses the complete spectrum of authorization challenges: from identity federation and claims normalization, through policy engine selection and hybrid architectures, to per-step agent authorization, MCP security, RAG data protection, and production governance.

The series is designed for enterprise architects, security engineers, platform engineers, and compliance officers at organizations deploying AI agents in regulated environments — particularly banking, financial services, healthcare, and government.

Series Volume Map

Vol	Title	Primary Topics	Key Deliverables
1	Executive Architecture & Authorization Fundamentals	Authorization landscape; PEP/PDP/PAP/PIP; Zero Trust; embedded vs externalized; STRIDE threat model; compliance mapping	Authorization engine comparison; PEP pattern matrix; STRIDE analysis; compliance control map; anti-pattern catalogue
2	Identity, Claims & Policy Design	ADFS & Entra ID federation; JWT claims normalization; canonical enterprise claim model; Cedar policy design; Rego policy design; Cedar vs Rego matrix; hybrid architecture	Canonical claims schema; role→capability mapping framework; Cedar entity schema; Cedar policy patterns; Rego policy examples; Cedar vs Rego comparison matrix
3	Agent, Tool & MCP Authorization	Agent authorization lifecycle; per-step policy evaluation; tool capability taxonomy; contextual signals; MCP server security; multi-agent workflows; human-in-the-loop	Agent authorization decision matrix; tool capability catalogue; context signal catalogue; MCP authorization architecture; sequence diagrams; HITL Cedar patterns
4	RAG, Memory & Data Authorization	Document-level authorization; chunk-level filtering; vector database pre/post filtering; memory type taxonomy; multi-tenant isolation; output classification; DLP integration	RAG authorization pipeline; document metadata schema; Cedar RAG policies; memory authorization patterns; tenant isolation framework; output classification model
5	AWS Implementation & Governance	AWS reference architecture; component justification; performance benchmarks; caching strategy; policy CI/CD; enterprise case studies; migration roadmap; production checklist	AWS architecture diagram; component matrix; performance targets; CI/CD pipeline; test framework; migration phases; production readiness checklist; decision framework

Reading Guide by Role

Role	Must Read	Recommended
Enterprise Architect	All volumes	Focus on Vol 1 frameworks and Vol 5 AWS architecture
Security Engineer	Vol 1, 2, 3	Vol 4 for data security; Vol 5 for threat model
Platform/DevOps Engineer	Vol 5, Vol 2 (policy CI/CD)	Vol 3 for MCP/tool deployment patterns

Role	Must Read	Recommended
Compliance Officer	Vol 1 (compliance section), Vol 5 (checklist)	Vol 4 for data residency and DLP
AI/ML Engineer	Vol 3 (agent auth), Vol 4 (RAG/memory)	Vol 2 for Cedar policy context
Identity/IAM Engineer	Vol 2 (claims normalization)	Vol 1 for authorization landscape
CTO / CISO	Vol 1 (executive summary), Vol 5 (case studies)	Series index (this document)

Key Architectural Decisions at a Glance

- **Authorization Engine:** Amazon Verified Permissions (Cedar) for application/agent authorization; OPA/Rego for infrastructure and Kubernetes. Hybrid architecture with shared claims normalization.
- **PEP Location:** API Gateway Lambda Authorizer (external requests) + Application middleware (internal fine-grained) + MCP PEP Gateway (tool invocation).
- **Identity Integration:** Entra ID (primary OIDC) + ADFS (legacy SAML federation) → Claims Normalization Service → Canonical Claims → Cedar entity context.
- **Claims Abstraction:** Entra groups and roles are NEVER referenced in Cedar policies. Always mapped to business capabilities in the normalization layer.
- **Default Posture:** Default deny everywhere. Unreachable PDP = deny. Missing context = deny. Explicit permit required for every authorized action.
- **Agent Trust Model:** Agents receive intersection of their permitted scope and the delegating user's capabilities. Never union. Scope is constrained at delegation time.
- **Tenant Isolation:** Mandatory Cedar forbid policies enforce tenant isolation at policy layer. Defense-in-depth: also enforced at storage partition, IAM, and network layers.
- **Caching Strategy:** 4-layer cache: Lambda IAM policy cache → ElastiCache claims cache → ElastiCache PIP cache → OPA in-memory bundle. Target: >90% cache hit rate.
- **Audit Trail:** CloudTrail captures every AVP IsAuthorized call. Decision logs: principal, action, resource, context hash, policy matched, decision reason.
- **Policy Lifecycle:** GitOps: policies in Git → PR review → automated tests → shadow eval → canary deploy → production → drift detection. <15 min deploy, <5 min rollback.

Authorization Component Quick Reference

Component	AWS Service / Tech	Volume Reference
Primary PDP (Business)	Amazon Verified Permissions (Cedar)	Vol 1, 2
Infrastructure PDP	OPA / Rego (ECS sidecar / EKS DaemonSet)	Vol 2
API Gateway PEP	API Gateway + Lambda Authorizer	Vol 1, 5
Tool/MCP PEP	ECS Fargate MCP Gateway	Vol 3
Claims Normalization	ECS Fargate microservice + ElastiCache	Vol 2
PIP Attribute Store	DynamoDB + ElastiCache Redis	Vol 1, 5
Risk Engine	AWS Fraud Detector + GuardDuty	Vol 3, 5
RAG Vector Search	OpenSearch (with pre-filter)	Vol 4
Memory Store	DynamoDB + Redis + S3	Vol 4
Output Filter / DLP	Bedrock Guardrails + Amazon Macie	Vol 4
Human Approval Workflow	AWS Step Functions (wait-for-task)	Vol 3
Audit Log	CloudTrail → S3 (immutable)	Vol 5
Policy Store (Cedar)	AVP Policy Store	Vol 2, 5
Policy Store (OPA)	S3 Bundle Server	Vol 2, 5
Policy CI/CD	CodePipeline / GitHub Actions	Vol 5
Token Exchange	AWS STS + RFC 8693 Service	Vol 2
Encryption	AWS KMS (per-tenant CMK)	Vol 5
Secrets Management	AWS Secrets Manager	Vol 5
Threat Detection	GuardDuty + Security Hub	Vol 5

✓ BEST PRACTICE

This series represents the state-of-the-art in enterprise Agentic AI authorization as of 2025. The frameworks, patterns, and AWS services described are production-validated by enterprises including Capital One, Netflix, Intuit, and major financial institutions. The hybrid Cedar + OPA architecture with canonical claims normalization is the reference architecture recommended for all regulated AWS-hosted Agentic AI deployments.